

TLS - Transport Layer Security

Eine Betrachtung von TLS hinsichtlich Sicherheit und Robustheit

1st Sina <Nachname>
HKA
Hochschule Karlsruhe
rz-kürzel@h-ka.de

2nd <Vorname> <Nachname>
HKA
Hochschule Karlsruhe
rz-kürzelh-ka.de

3rd <Vorname> <Nachname>
HKA
Hochschule Karlsruhe
rz-kürzel@h-ka.de

4th Niels Reisch
HKA
Hochschule Karlsruhe
reni1030@h-ka.de

Abstract—Transport Layer Security (TLS) bildet das kryptographische Fundament sicherer Netzwerkkommunikation. Diese Arbeit analysiert den TLS-Handshake-Prozess, die Zertifikatsvalidierung sowie Vertrauensketten anhand zweier kontrastierender Client-Server-Szenarien: einer gehärteten TLS 1.3-Konfiguration mit Perfect Forward Secrecy und einem System mit veralteter Protokollversion und schwachen Cipher Suites. Am Beispiel des POODLE-Angriffs (CVE-2014-3566) wird ein gezielter Protokoll-Downgrade auf SSL 3.0 simuliert und anhand synthetischer Handshake-Logs nachvollzogen, an welcher Stelle die Sicherheitsmechanismen versagen. Ergänzend wird das Szenario eines selbstsignierten Zertifikats untersucht, das den Handshake mit einem CERTIFICATE_UNKNOWN-Alert abbricht und die Verwundbarkeit gegenüber Impersonation-Angriffen aufzeigt. Die Bewertung der Auswirkungen auf Vertraulichkeit, Integrität und Authentizität zeigt, dass Legacy-Protokolle alle drei Schutzziele gleichermaßen gefährden. Als Härungsmaßnahmen werden die ausschließliche Verwendung von TLS 1.2 und TLS 1.3, der Einsatz von Cipher Suites mit Perfect Forward Secrecy, OCSP Stapling, Certificate Transparency sowie HTTP Strict Transport Security diskutiert und im Einklang mit der BSI-Technischen Richtlinie TR-02102-2 bewertet.

Index Terms—Transport Layer Security, TLS Handshake, Downgrade-Angriff, POODLE, Cipher Suite, Perfect Forward Secrecy, Zertifikatsvalidierung, Public Key Infrastructure, Härungsmaßnahmen, IT-Sicherheit

I. AUFGABENSTELLUNG

Erläutern Sie die Funktionsweise von TLS, insbesondere den Handshake-Prozess, Zertifikatsprüfung und Vertrauensketten. Entwerfen Sie ein Szenario mit mindestens zwei Client-Server-Paaren mit unterschiedlichen TLS-Konfigurationen (z. B. sichere Konfiguration, veraltete Version, schwache Cipher Suite oder selbstsigniertes Zertifikat). Simulieren Sie einen Downgrade- oder Handshake-Fehlerfall. Beschreiben Sie die einzelnen Schritte des Verbindungsaufbaus und analysieren Sie anhand von Logs oder Paketmitschnitten, an welcher Stelle die Sicherheitsmechanismen versagen oder geschwächt werden. Bewerten Sie die Auswirkungen auf Vertraulichkeit, Integrität und Authentizität. Entwickeln Sie abschließend konkrete Härungsmaßnahmen und begründen Sie, warum diese die identifizierten Schwachstellen wirksam verhindern.

II. FUNKTIONSWEISE VON TLS

Handshake

Zertifikatsprüfung

Vertrauensketten

III. KONFIGURATIONEN VON TLS

Sichere Konfiguration

veraltete Konfiguration

IV. TLS FEHLER

Forsiertes Downgrade

Der POODLE-Angriff (Padding Oracle On Downgraded Legacy Encryption, CVE-2014-3566) zeigt exemplarisch, wie ein Angreifer in der Mitte (Mallory) einen modernen TLS-Verbindungsversuch systematisch auf das unsichere Protokoll SSL 3.0 herabstuft. Voraussetzung ist, dass sowohl Client als auch Server SSL 3.0 als Fallback unterstützen und der sogenannte „Downgrade Dance“ nicht durch TLS_FALLBACK_SCSV (RFC 7507) blockiert wird.

Der BEAST-Angriff (Browser Exploit Against SSL/TLS) ist ein Man-in-the-Middle-Angriff, der eine Schwachstelle im Cipher Block Chaining (CBC)-Modus der Protokolle SSL 3.0 und TLS 1.0 ausnutzt. Er wurde 2011 von den Sicherheitsforschern Thai Duong und Julian Rizzo praktisch demonstriert und ermöglicht es Angreifern, sensible Daten wie Session-Cookies aus verschlüsselten Verbindungen auszuspähen.

Handshake Fehler

V. AUSWIRKUNGEN EINES FEHLERFALLS AUF SCHUTZZIELE

TABLE I
AUSWIRKUNGEN AUF DIE SCHUTZZIELE (CIA)

Schutzziel	Angriff POODLE [7]	Self-Signed-Cert
Vertraulichkeit	✗ Verletzt	○ Gefährdet
Integrität	✗ Verletzt	○ Partiiell
Authentizität	✗ Verletzt	✗ Verletzt

✗ = verletzt; ○ = partiell gefährdet

In Tabelle I sind die die Auswirkungen zusammengefasst.

Angriff POODLE

Der POODLE-Angriff (Padding Oracle On Downgraded Legacy Encryption, CVE-2014-3566) zeigt wie ein Angreifer eine Verbindung von TLS auf SSL 3.0 downgraded und dadurch die Verbindung kompromittiert. Die Padding-Oracle-Eigenschaft von SSL 3.0 im CBC-Modus ermöglicht die iterative Rekonstruktion von Klartextbytes durch einen Angreifer im Netzpfad (*Vertraulichkeit*). Manipulierte CBC-Blöcke werden akzeptiert, sofern das Padding zufällig korrekt ist – die MAC-then-Encrypt-Konstruktion bietet keinen ausreichenden Schutz (*Integrität*). Mit dem erzwungenen Wechsel auf SSL 3.0 entfallen die Finished-Message-Signaturen moderner TLS-Versionen; ohne TLS_FALLBACK_SCSV bleibt der Downgrade unbemerkt (*Authentizität*).

Selbstsigniertes Zertifikat

Präsentiert ein Server ein selbstsigniertes Zertifikat, bricht ein korrekt konfigurierter Client den Handshake mit einem CERTIFICATE_UNKNOWN-Alert ab – die Verbindung kommt nicht zustande. Deaktiviert ein Nutzer diese Prüfung jedoch (z. B. durch Akzeptieren einer Browser-Warnung oder mittels `--no-verify-Flag`), öffnet sich ein Angriffsfenster: Ein Angreifer im Netzpfad kann ein eigenes selbstsigniertes Zertifikat einschleusen, das der Client mangels CA-Prüfung ebenfalls akzeptiert. Damit terminiert der Angreifer *beide* TLS-Verbindungen separat – zum Client und zum echten Server – und leitet Daten transparent weiter (*Man-in-the-Middle*). Alle übertragenen Klartextdaten sind dem Angreifer zugänglich, obwohl der Nutzer eine `https://`-Verbindung im Browser sieht (*Vertraulichkeit verletzt, Authentizität verletzt*). Die TLS-Record-MAC-Prüfung schützt die Integrität *innerhalb* jeder der beiden Teilverbindungen – der Angreifer kann jedoch Inhalte modifizieren, bevor er sie in der zweiten Verbindung weitersendet, sodass der Endnutzer manipulierte Daten als integer wahrnimmt (*Integrität de facto verletzt*).

VI. HÄRTUNGSMASSNAHMEN

TLS Versionsbeschränkung

Das BSI schreibt in der **Technischen Richtlinie TR-02102-2** (Stand: Januar 2026) vor, dass in neuen Systemen ausschließlich TLS 1.2 und TLS 1.3 eingesetzt werden sollen [2]. SSL 2.0, SSL 3.0 und TLS 1.0 sind vollständig zu deaktivieren; TLS 1.1 wird ebenfalls nicht mehr empfohlen. Die Konfiguration in nginx lautet entsprechend:

```
ssl_protocols TLSv1.2 TLSv1.3;
```

Durch die Abschaltung aller Legacy-Protokolle entfällt die Angriffsfläche für POODLE und BEAST [8] grundlegend, da kein Protokoll-Fallback mehr stattfinden kann [3]. Ergänzend sollte **TLS_FALLBACK_SCSV** (RFC 7507) implementiert werden: Übermittelt ein Client diesen Signaling Cipher Suite Value in einem erneuten, herabgestuften Verbindungsversuch, bricht der Server den Handshake mit einem `inappropriate_fallback`-Alert ab und verhindert so auch aktive Downgrade-Versuche bei Systemen, die Legacy-Versionen aus Kompatibilitätsgründen noch führen.

Sichere Cipher Suites

Algorithmen ohne kryptographische Langzeitsicherheit – darunter RC4, DES, 3DES, Export-Cipher und MD5-basierte MACs – sind vollständig aus der Konfiguration zu entfernen [2]. Gemäß BSI TR-02102-2 sind ausschließlich Cipher Suites mit **Perfect Forward Secrecy (PFS)** zu verwenden: Nur ephemere Schlüsselaustauschverfahren (ECDHE, DHE) stellen sicher, dass ein nachträglich kompromittierter Langzeitschlüssel keine bereits aufgezeichneten Sessions entschlüsselbar macht. Empfohlene Suites für TLS 1.2 sind:

```
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
```

Für TLS 1.3 sind die verfügbaren Cipher Suites protokollseitig bereits auf AEAD-Verfahren (AES-GCM, ChaCha20-Poly1305) beschränkt; RC4, CBC sowie der statische RSA-Schlüsseltransport sind im Standard nicht mehr vorgesehen [4].

Zertifikatsvalidierung und Vertrauensketten

Selbstsignierte Zertifikate sind in produktiven Umgebungen unzulässig. Es sind Zertifikate einer anerkannten Zertifizierungsstelle einzusetzen, deren Root-Zertifikate in den Betriebssystem- und Browser-Trust-Stores enthalten sind. Zur weiteren Absicherung der Vertrauenskette empfehlen sich folgende Mechanismen:

- **Certificate Transparency (CT):** Alle ausgestellten Zertifikate werden in öffentliche, append-only-Logs eingetragen. Clients und Monitore können überprüfen, ob ein präsentiertes Zertifikat dort verzeichnet ist, und unautorisierte Ausstellungen frühzeitig erkennen.
- **OCSP Stapling:** Der Server liefert den aktuellen Sperrstatus seines Zertifikats unmittelbar im TLS-Handshake mit, sodass der Client keinen separaten OCSP-Request senden muss. Dies verhindert, dass ein Angreifer OCSP-Abfragen blockiert und ein bereits widerrufenes Zertifikat weiterhin nutzbar bleibt.
- **CAA-DNS-Einträge:** *Certification Authority Authorization* Records schränken auf DNS-Ebene ein, welche Zertifizierungsstellen für eine Domain überhaupt Zertifikate ausstellen dürfen, und verringern so das Risiko unberechtigter Ausstellungen.

HTTP Strict Transport Security (HSTS)

Über den Strict-Transport-Security-Antwort-Header teilt der Server dem Browser verbindlich mit, dass die Domain ausschließlich über HTTPS erreichbar ist. Selbst bei einem aktiven Downgrade-Versuch auf HTTP baut der Browser keine unverschlüsselte Verbindung auf:

```
Strict-Transport-Security: max-age=31536000;
includeSubDomains; preload
```

Die Aufnahme in die **HSTS-Preload-Liste** (hstspreload.org) bewirkt, dass dieser Schutz bereits beim allerersten Verbindungsversuch gilt – ohne eine initiale, potenziell abfangbare HTTP-Anfrage.

Regelmäßige Überprüfung und Patch-Management

Da Schwachstellen kontinuierlich neu entdeckt werden (vgl. MITRE CVE-Datenbank), ist eine **regelmäßige Überprüfung der TLS-Konfiguration** zwingend erforderlich. Werkzeuge wie testssl.sh oder der Qualys SSL Labs Server Test erlauben eine automatisierte Analyse aktiver Protokollversionen, Cipher Suites und Zertifikatseigenschaften. Das BSI macht die TR-02102-2 für Bundesbehörden gemäß § 8 Abs. 1 BSIG verbindlich und aktualisiert die Richtlinie fortlaufend – zuletzt im Januar 2026 [5].

REFERENCES

- [1] Vorlesungsfolien und Übungsaufgaben zur Vorlesung "IT-Sicherheit", Hochschule Karlsruhe.
- [2] Bundesamt für Sicherheit in der Informationstechnik (BSI), *Technische Richtlinie TR-02102-2: Kryptographische Verfahren – Verwendung von Transport Layer Security (TLS)*, Version 2026-01, <https://www.bsi.bund.de/TR02102>.
- [3] Thomas-Krenn-Wiki, *SSL 3.0 POODLE Attack*, 2023, https://www.thomas-krenn.com/de/wiki/SSL_3.0_POODLE_Attack.
- [4] Der Windows Papst, *Recommended Cipher Suites 2025*, Juni 2024, <https://www.der-windows-papst.de/2024/06/24/recommended-cipher-suites-2025/>.
- [5] *kes – Zeitschrift für Informations-Sicherheit*, *Technische Richtlinien des BSI zur Kryptografie*, 2025, <https://www.kes-informationssicherheit.de>.
- [6] Mozilla, "SSL Configuration Generator." [Online]. <https://ssl-config.mozilla.org/>
- [7] NIST National Vulnerability Database, *CVE-2014-3566: SSL 3.0 Padding Oracle Vulnerability*, 2014. [Online]. Verfügbar: <https://nvd.nist.gov/vuln/detail/CVE-2014-3566>
- [8] NIST National Vulnerability Database, *CVE-2011-3389: TLS 1.0 CBC Predictable IV (BEAST)*, 2011. [Online]. Verfügbar: <https://nvd.nist.gov/vuln/detail/CVE-2011-3389>